



TỔNG QUAN VỀ AN TOÀN THÔNG TIN

Giảng viên : Ths. Trịnh Lê Hoàng Tuấn

NỘI DUNG :

1. Tổng quan về an toàn thông tin
2. Hệ thống thông tin và vấn đề an ninh
3. An toàn thông tin
4. Các công cụ đảm bảo an toàn thông tin
5. Các bài toán cơ bản trong an toàn thông tin

Thông tin là gì ?

- Thông tin là một khái niệm trừu tượng mô tả những gì đem lại hiểu biết và nhận thức cho con người.
 - **Có 2 cách biểu diễn thông tin :**
 - **Cách tự nhiên**
 - **Cách có cấu trúc**
- > so sánh thông tin và dữ liệu.**



Hệ thống thông tin

- Hệ thống thông tin được xác định như một tập hợp các thành phần được tổ chức thu thập, xử lý, lưu trữ và khai thác thông tin hỗ trợ việc ra quyết định và kiểm soát thông tin.
- Hệ thống thông tin là tài sản quan trọng nhưng cũng có nhiều yếu điểm và rủi ro.
- Việc mất mát rò rỉ có thể ảnh hưởng rất lớn đến doanh nghiệp.



Các mối đe dọa

Có 3 hình thức chủ yếu đe dọa đối với hệ thống:

- Phá hoại: phá hỏng các thiết bị phần cứng ,phần mềm hoặc hệ thống.
- Sửa đổi: tài nguyên của hệ thống bị sửa đổi trái phép như thay đổi mật khẩu, quyền truy cập vào hệ thống làm sai chức năng trong hệ thống.
- Can thiệp: nguồn tài nguyên hệ thống bị truy cập trái phép.



Các đối tượng gây ra các mối đe dọa

- Có thể chia thành 3 loại đối tượng như sau:
- Đối tượng từ ngay bên trong hệ thống : nhân viên hoặc những người quản lý trực tiếp hệ thống.
- Đối tượng bên ngoài hệ thống : như hacker, cracker thường tấn công thông qua truyền tin Internet
- Đối tượng thứ ba là các phần mềm : như spyware, adware chạy trên hệ thống.



Các biện pháp ngăn chặn

- Có 3 biện pháp :
- Điều khiển thông qua phần mềm : các cơ chế an toàn bảo mật của hệ thống.
- Điều khiển thông qua phần cứng : Các cơ chế bảo mật và thuật toán mã hóa
- Điều khiển thông qua các chính sách.

CÁC MỤC TIÊU AN NINH MẠNG

Mục tiêu thực hiện an ninh mạng phải đạt 5 bước sau :

Bước 1: Xác định tài sản cần bảo vệ

Bước 2: Xác định cố gắng bảo vệ nó từ cái gì.

Bước 3: Xác định các nguy cơ nào là có thể

Bước 4: Thực hiện các biện pháp để bảo vệ các tài sản

Bước 5: Kiểm tra lại các tiến trình một cách liên tiếp, và thực hiện các cải tiến với mỗi lần tìm ra một điểm yếu.

XÁC ĐỊNH TÀI SẢN

- Thiết bị mạng như là các thiết bị định tuyến (router), các thiết bị chuyển mạch (switch), và các thiết bị tường lửa (firewall),
- Các thông tin vận hành mạng như là các bảng định tuyến và các cấu hình danh sách truy nhập được lưu trữ trong thiết bị này.
- Các tài nguyên để mạng làm việc được như là băng thông và dung lượng bộ nhớ các loại.

XÁC ĐỊNH TÀI SẢN

- Thông tin và các nguồn thông tin có liên quan đến mạng, như là cơ sở dữ liệu và các máy chủ.
- Các trạm đầu cuối khi kết nối với mạng để tạo ra việc sử dụng các tài sản khác nhau.
- Các thông tin lưu chuyển qua mạng

ĐÁNH GIÁ CÁC MỐI ĐE DỌA

Các cuộc tấn công mạng có thể được chia thành ba loại:

1. Truy nhập trái phép vào các tài sản hoặc thông tin thông qua việc sử dụng mạng với mục đích ăn cắp, hoặc lừa đảo.
2. Thao tác hoặc sửa đổi trái phép các thông tin trên mạng với mục đích phá hoại.
3. Tạo ra sự từ chối các dịch vụ mạng đối với các người sử dụng hợp pháp.

ĐÁNH GIÁ CÁC RỦI RO

Có hai yếu tố chính ảnh hưởng đến rủi ro:

- Khả năng cuộc tấn công sẽ được thực hiện nhằm chống lại tài sản đang bàn đến.
- Giá thành sẽ phải gánh chịu cho các thiệt hại của mạng khi mà cuộc tấn công thành công.

XÂY DỰNG CHÍNH SÁCH AN NINH

- Chính sách an ninh mạng xác định khuôn khổ công việc để bảo vệ các tài sản gắn chặt với mạng dựa trên việc phân tích các rủi ro
- Chính sách an ninh mạng xác định các giới hạn truy nhập và các quy tắc cho việc truy nhập vào các tài sản khác nhau gắn liền với mạng.
- Đây là nguồn thông tin cho các người sử dụng và các người quản lý như chúng đã được thiết lập, để sử dụng và kiểm tra mạng.

THỰC HIỆN CHÍNH SÁCH AN NINH

- Việc thực hiện chính sách an ninh không phải là vấn đề đơn giản. Nó bao hàm cả các vấn đề kỹ thuật và tổ chức.
- Tất cả các bên liên quan phải đồng ý hoặc có sự nhất trí về chính sách an ninh.
- Thực tế thì an ninh phải trả một giá rất đắt, và còn thường xuyên phải trả thêm nữa chứ không chỉ phải trả có một lần.

THỰC HIỆN KIẾN TRÚC AN NINH

Sau khi chính sách an ninh đã được thiết lập là chuyển nó thành các thủ tục.

- Các thủ tục này là sự sắp đặt điển hình như là một tập các nhiệm vụ mà phải hoàn thành cho việc thực thi thành công chính sách.
- Các thủ tục này dựa vào kết quả thực hiện trong thiết kế mạng

THỰC HIỆN KIẾN TRÚC AN NINH

- Các mật khẩu và SSH trên các thành phần mạng
- Tường lửa và VPN
 - Các thiết phát hiện và phòng chống xâm nhập
 - Các máy chủ xác thực, định danh và kiểm toán (AAA) và các dịch vụ AAA
- Điều khiển truy nhập và các cơ chế hạn chế truy nhập

KIỂM TRA VÀ CẢI TIẾN CHÍNH SÁCH AN NINH

- Ngay sau khi một chính sách an ninh đã được thực hiện, công việc cấp thiết tiếp theo là liên tục phân tích, kiểm tra và cải tiến nó.
- Có thể làm điều này thông qua hình thức các kiểm tra hệ thống an ninh, cũng như thông qua hình thức các phép đo thử vận hành hàng ngày.



Các mục tiêu đảm bảo an toàn thông tin

- *Tính riêng tư* (confidentiality)
- *Tính toàn vẹn* (Integrity)
- *Tính sẵn sàng* (availability)

Mô hình CIA



TÍNH RIÊNG TƯ

- Riêng tư (bí mật) là sự ngăn ngừa việc tiết lộ trái phép những thông tin quan trọng, nhạy cảm. Đó là khả năng đảm bảo mức độ bảo mật cần thiết được tuân thủ và thông tin quan trọng, nhạy cảm đó được che giấu với người dùng không được cấp phép.
- Đối với an ninh mạng thì tính bí mật rõ ràng là điều đầu tiên được nói đến và nó thường xuyên bị tấn công nhất.

TÍNH TOÀN VỆ

- Toàn vẹn là sự phát hiện và ngăn ngừa việc sửa đổi trái phép về dữ liệu, thông tin và hệ thống, do đó đảm bảo được sự chính xác của thông tin và hệ thống.
- Có 3 nguyên nhân chính:
 - Do tác động từ những người không có quyền truy cập
 - Do tác động của những người có quyền truy cập
 - Duy trì sự toàn vẹn dữ liệu từ bên trong và bên ngoài.

TÍNH SẴN SÀNG

- Tính sẵn sàng bảo đảm các người sử dụng hợp pháp của hệ thống có khả năng truy cập đúng lúc và không bị ngắt quãng tới các thông tin trong hệ thống và tới mạng.
- Tính sẵn sàng có liên quan đến độ tin cậy của hệ thống.

Các chức năng khác

- **Sự định danh** (Identification): hành động của người sử dụng khi xác nhận một sự định danh tới hệ thống, ví dụ định danh thông qua tên (username) của cá nhân.
- **Sự xác thực** (Authentication): sự xác minh rằng định danh đã khai báo của người sử dụng là hợp lệ, ví dụ thông qua việc sử dụng một mật khẩu (password).
- **Sự kiểm toán** (Accountability): sự xác định các hành động hoặc hành vi của một cá nhân bên trong hệ thống và nắm chắc được trách nhiệm cá nhân hoặc các hành động của họ.

Các chức năng khác

- **Sự ủy quyền** (Authorization): các quyền được cấp cho một cá nhân (hoặc tiến trình) mà chúng cho phép truy cập vào tài nguyên trên mạng hoặc máy tính.
- **Sự chống chối từ** (Non-repudiation): bảo đảm không có khả năng chối bỏ hành động đã thực hiện ở người gửi và người nhận.



An toàn thông tin

- An toàn thông tin là một khái niệm liên quan việc bảo vệ tài sản thông tin. Đó là lĩnh vực rộng lớn bao gồm cả những sản phẩm và quy trình nhằm ngăn chặn truy cập trái phép, hiệu chỉnh, xóa thông tin.....
- An toàn thông tin là bảo vệ hệ thống khỏi những tai họa sự tác động không mong đợi hoặc không an toàn.



Các yêu cầu của việc trao đổi thông tin và nguyên tắc cơ bản

- gồm có 5 nguyên tắc cơ bản sau:
 - Tính bí mật
 - Tính toàn vẹn
 - Tính xác thực
 - Tính chống chối từ
 - Tính nhận dạng



Vấn đề an toàn thông tin

- Vấn đề an toàn thông tin được hiểu trên 2 phương diện:
 - An toàn máy tính: là sự bảo vệ các thông tin cố định bên trong máy tính -> thông tin tĩnh
 - An toàn truyền tin: là sự bảo vệ các thông tin trên đường truyền tin -> thông tin động



Các hành vi xâm phạm thông tin

- có 2 hành vi:
 - Vi phạm chủ động: làm thay đổi nội dung thông tin có thể xóa , sửa nội dung.
 - Vi phạm thụ động : nắm bắt thông tin nhưng không làm sai lệch hoặc hủy nội dung thông tin



Các chiến lược đảm bảo an toàn thông tin

- Giới hạn quyền tối thiểu
- Bảo vệ theo chiều sâu
- Nút thắt
- Điểm nổi yếu nhất
- Tính toàn cục
- Tính đa dạng bảo vệ



Các phương pháp đảm bảo an toàn thông tin

- được chia làm 3 nhóm sau :
 - các biện pháp hành chính
 - Phương pháp kỹ thuật phần cứng
 - Phương pháp thuật toán phần mềm



Các phương pháp đảm bảo an toàn thông tin

1. Phương pháp che giấu nhằm đảm bảo toàn vẹn và xác thực thông tin
 - Che thông tin (hay mã hóa) là thay đổi thông tin gốc làm cho người đọc khó nhận biết thông tin gốc.
 - Giấu thông tin là cất thông tin trong một môi trường khác.
 - Các thuật toán được áp dụng : mã hóa, hàm băm, ký số....



Các phương pháp đảm bảo an toàn thông tin

2. Phương pháp kiểm soát lối vào ra thông tin

- Các biện pháp ngăn chặn thông tin ra vào hệ thống
- Kiểm soát cấp quyền, chính sách....
- Kiểm soát virus....
- Các kỹ thuật áp dụng: mật khẩu mạnh, tường lửa, VPN, xác thực, policy....



Các phương pháp đảm bảo an toàn thông tin

3. Phát hiện và xử lý các lỗ hổng

- Các lỗ hổng trong các thuật toán
- Các lỗ hổng trong các giao thức mạng
- Các lỗ hổng trong các hệ điều hành
- Các lỗ hổng trong các ứng dụng
- Các kỹ thuật áp dụng: kiểm tra, giám sát, cập nhật phiên bản....

Các phương pháp đảm bảo an toàn thông tin

4. Phòng tránh các dạng tấn công

➤ Hệ thống luôn bị đe dọa bởi các nguy cơ tiềm ẩn mất an toàn. Có 4 mối đe dọa:

➤ Chặn bắt

➤ Đứt đoạn

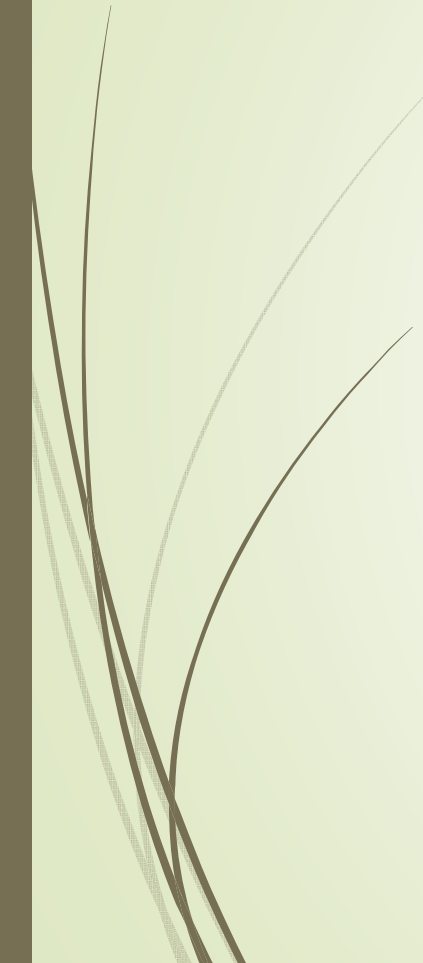
➤ Thay đổi

➤ Giả mạo

-> Dạng tấn công này thường phổ biến trên các giao dịch trực tuyến .

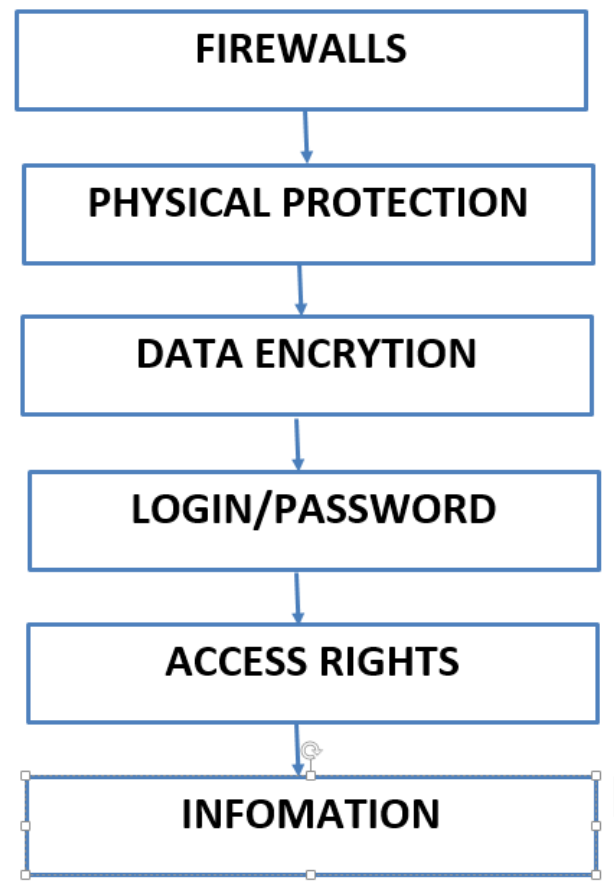


Các phương thức tấn công mạng phổ biến

- 
1. Điểm yếu của nhân viên và người dùng
 2. Mạo danh
 3. Khai thác lỗ hổng
 4. Tấn công dữ liệu
 5. Điểm yếu cơ sở hạ tầng
 6. Tấn công từ chối dịch vụ

- 
- Các hacker sử dụng các phương thức trên để chiếm quyền điều khiển và kiểm soát hệ thống.
 - Vì vậy cần phải đảm bảo thông tin cơ sở hạ tầng mạng truyền dữ liệu thông suốt nhằm đảm bảo hoạt động lưu thông và che giấu được nội dung thông tin.

Mức độ bảo vệ thông tin





Các kỹ thuật đảm bảo an toàn thông tin

- Kỹ thuật diệt trừ
- Kỹ thuật tường lửa
- kỹ thuật mạng riêng ảo
- Kỹ thuật mã hóa
- Kỹ thuật giấu tin
- Kỹ thuật thủy ký
- Kỹ thuật truy tìm giấu vết



Các công nghệ đảm bảo an toàn thông tin

- Một số công nghệ điển hình như :
 - Công nghệ chung : tường lửa, VPN, khóa công khai...
 - Công nghệ cụ thể : SSL, TLS, mật mã



Phạm vi ứng dụng về an toàn thông tin

- Phục vụ an ninh quốc phòng
- Phục vụ hoạt động xã hội
- Phục vụ hoạt động hành chính
- phục vụ hoạt động kinh tế
- phục vụ hoạt động giáo dục



Các công cụ đảm bảo an toàn thông tin

1. Mật mã học

- gồm có mã hóa (mật mã) và giải mã
- Mật mã là một ngành khoa học nghiên cứu cách viết và giữ thông tin một cách bí mật. Đó là phương thức đảm bảo sự bí mật cho thông tin hay che giấu thông tin
- Giải mã là kỹ thuật phân tích mã, kiểm tra tính bảo mật của nó hoặc phá vỡ sự bí mật của nó



Các công cụ đảm bảo an toàn thông tin

2. Giấu tin

- Giấu tin là giấu thông tin này vào bên trong một thông tin khác sẽ khó bị phát hiện và khó nhận biết.
- Giải pháp hữu hiệu để che giấu thông tin là kết hợp 2 phương pháp mã hóa và sau đó che giấu thông tin vào một thông tin khác.

Các công cụ đảm bảo an toàn thông tin

3. Nén thông tin

- Nén thông tin là kỹ thuật chuyển dữ liệu dạng “ dư thừa “ sang dạng “ ít thừa “, dữ liệu thu được sau khi nén sẽ nhỏ hơn dữ liệu gốc rất nhiều. Như vậy đỡ tốn bộ nhớ lưu trữ và tiết kiệm thời gian và chi phí đường truyền.
- Một số kỹ thuật nén như :
 - RLE
 - Độ dài biến động
 - Huffman

Mã hóa RLE (Run LEngth coding)

- hình thức này đơn giản bằng cách đếm số lần lặp lại của một giá trị dữ liệu.
- Nhược điểm : không phù hợp với dữ liệu là hình ảnh, biểu tượng.
- Ví dụ: AAAASSSSMMMMMMMMMMMM được mã hóa thành 4A5S10M

Mã hóa độ dài biến động

- là phương pháp mã hóa mỗi ký tự bởi một lượng bit nhất định khác nhau, ký tự nào xuất hiện nhiều lần sẽ được mã hóa bởi lượng bit ít hơn.
- Ví dụ : ABTACADABTA được mã hóa như sau :
 - A là 0 ; B là 1 ; T là 01; C là 10; D là 11
 - Tổng bit dùng là 15 bit.



Mã hóa Huffman

- là phương pháp mã hóa xây dựng theo cây nhị phân theo cách các nút lá xa gốc nhất (tần số sử dụng thấp) và các nút gần gốc cây nhị phân (tần số sử dụng cao)



Tường lửa

- Firewall là một kỹ thuật được tích hợp vào hệ thống mạng để chống lại sự truy cập trái phép. Hệ thống firewall gồm phần cứng và phần mềm
- Nhiệm vụ tường lửa quyết định người nào, dịch vụ nào bên ngoài được truy cập vào bên trong hệ thống máy tính hoặc truy cập ra bên ngoài hệ thống máy tính.



Các thành phần của tường lửa

- Về mặt vật lý
 - Gồm nhiều máy chủ kết nối với Router
 - Các phần mềm quản lý an ninh trên hệ thống máy chủ: xác thực, phân quyền, kiểm toán....
- Về mặt chức năng
 - Bộ lọc packet
 - Proxy Server
 - Application Gateway



VPN

- **Mục đích:** đảm bảo trao đổi thông tin an toàn giữa các mạng nội bộ cũng như những máy tính riêng lẻ qua mạng công cộng bằng cách mã hóa các giao dịch trên mạng.
- VPN đảm bảo các yêu cầu sau :
 - Tính bí mật, tính riêng tư
 - Tính toàn vẹn
 - Tính xác thực



VPN Tunneling Protocol

- IP Sec (IP Security): được phát triển bởi IETF, IPSec là một chuẩn mở đảm bảo quá trình trao đổi dữ liệu được an toàn và phương thức xác thực người dùng qua mạng công cộng.
- IPSec thực hiện ở tầng thứ 3 trong mô hình OSI. Vì thế chúng có thể chạy độc lập so với các ứng dụng chạy trên mạng.



VPN Tunneling Protocol

- Layer 2 Tunneling Protocol (L2TP VPN): được phát triển bởi Cisco. L2TP là sự kết hợp giữa layer 2 và PPTP được dùng để đóng gói các giao thức : FR; ATM.



Các bài toán trong an toàn thông tin

1. Các bài toán lý thuyết

- Bài toán về bảo mật thông tin : nén thông tin; mã hóa thông tin; giấu thông tin
- Bài toán về xác thực : sử dụng các hạ tầng khóa công khai hoặc mật khẩu.
- Bài toán về phân quyền, cấp quyền



Các bài toán trong an toàn thông tin

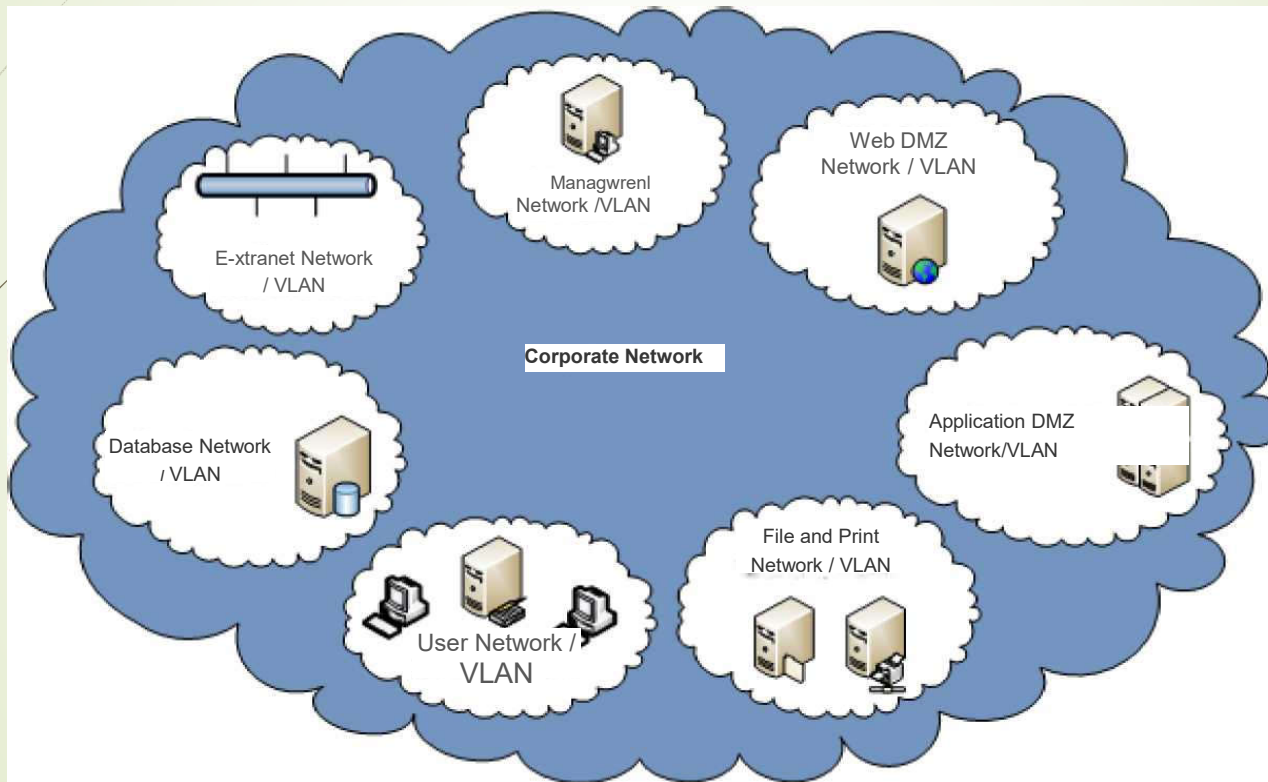
2. Các bài toán ứng dụng

- Bài toán về xây dựng hạ tầng CNTT: tường lửa; VPN; CA; PKI...
- Bài toán về kinh tế xã hội: các giao dịch điện tử; bỏ phiếu từ xa; đấu thầu điện tử.....

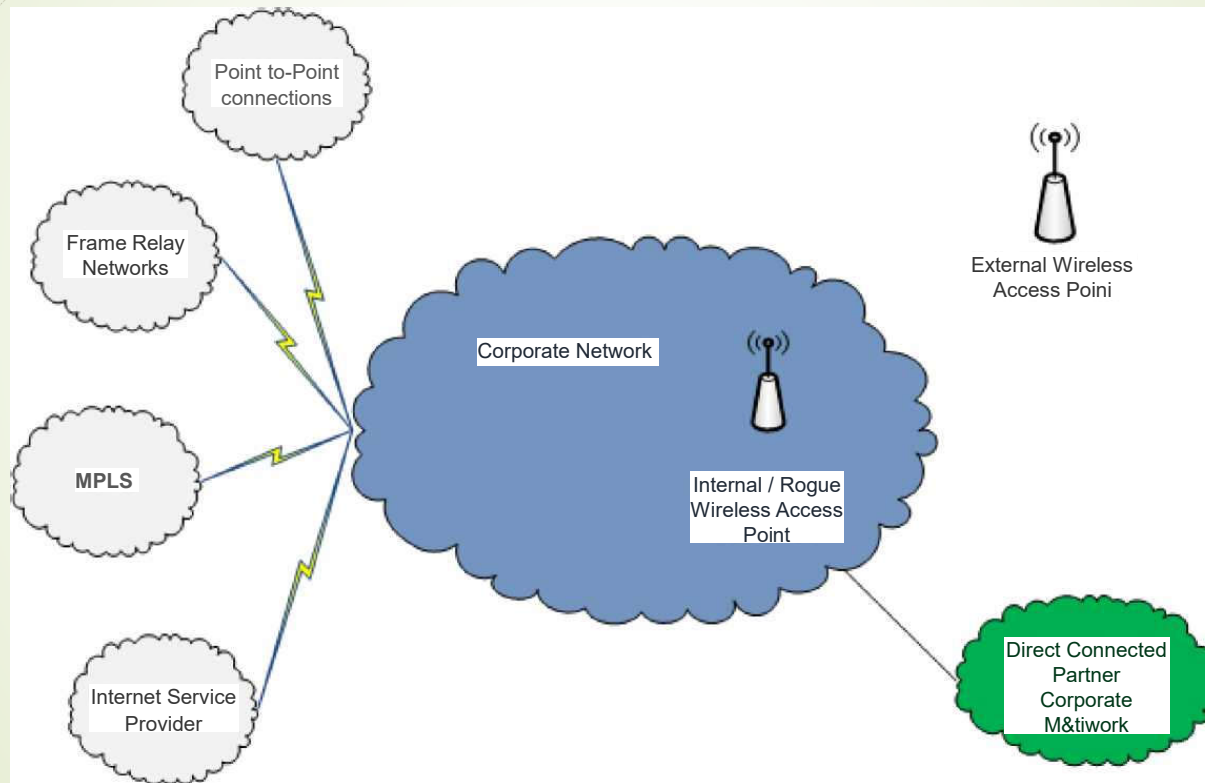
Các giải pháp thực tiễn trong vấn đề an ninh hệ thống

- Giải pháp phân mảnh mạng.
- Quản lý các điểm truy nhập.
- Các bộ định tuyến và chuyển mạch.
- Giải pháp bức tường lửa.
- Giải pháp lọc nội dung.
- Giải pháp phát hiện và phòng chống xâm nhập.
- Điều khiển truy nhập từ xa.

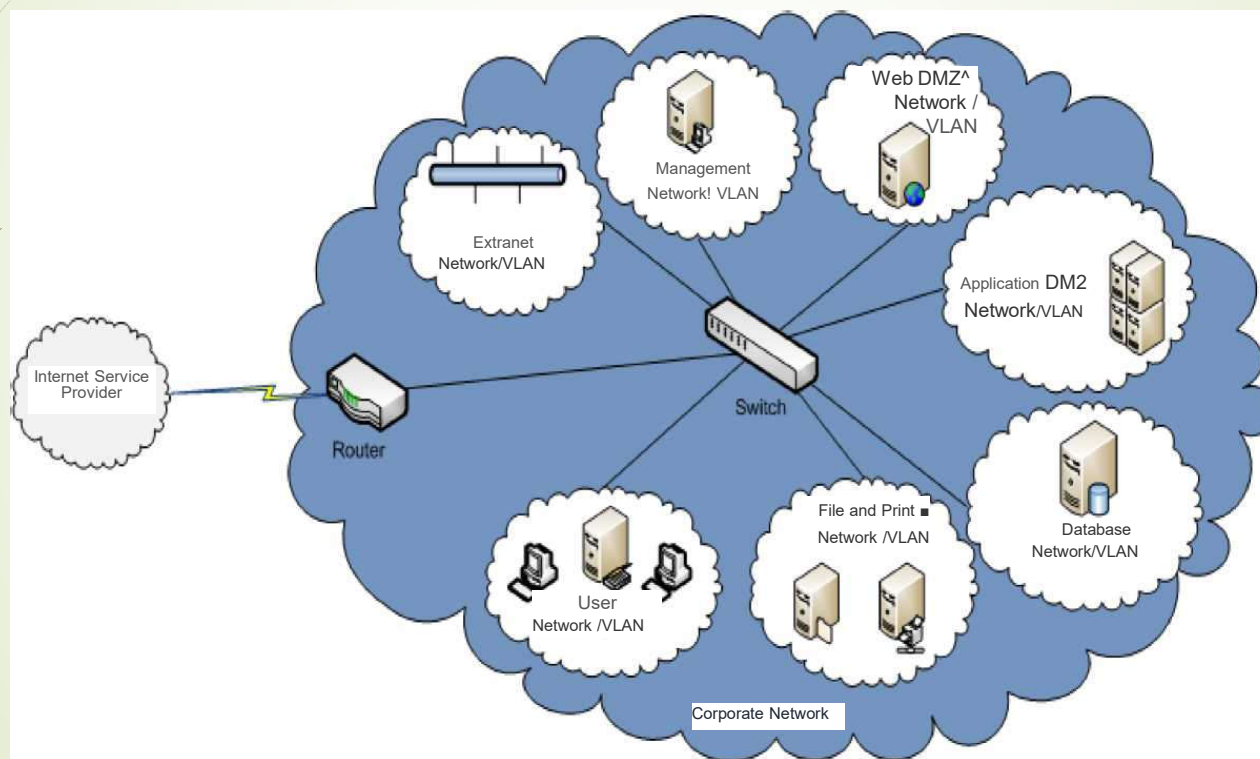
Giải pháp phân mảnh mạng



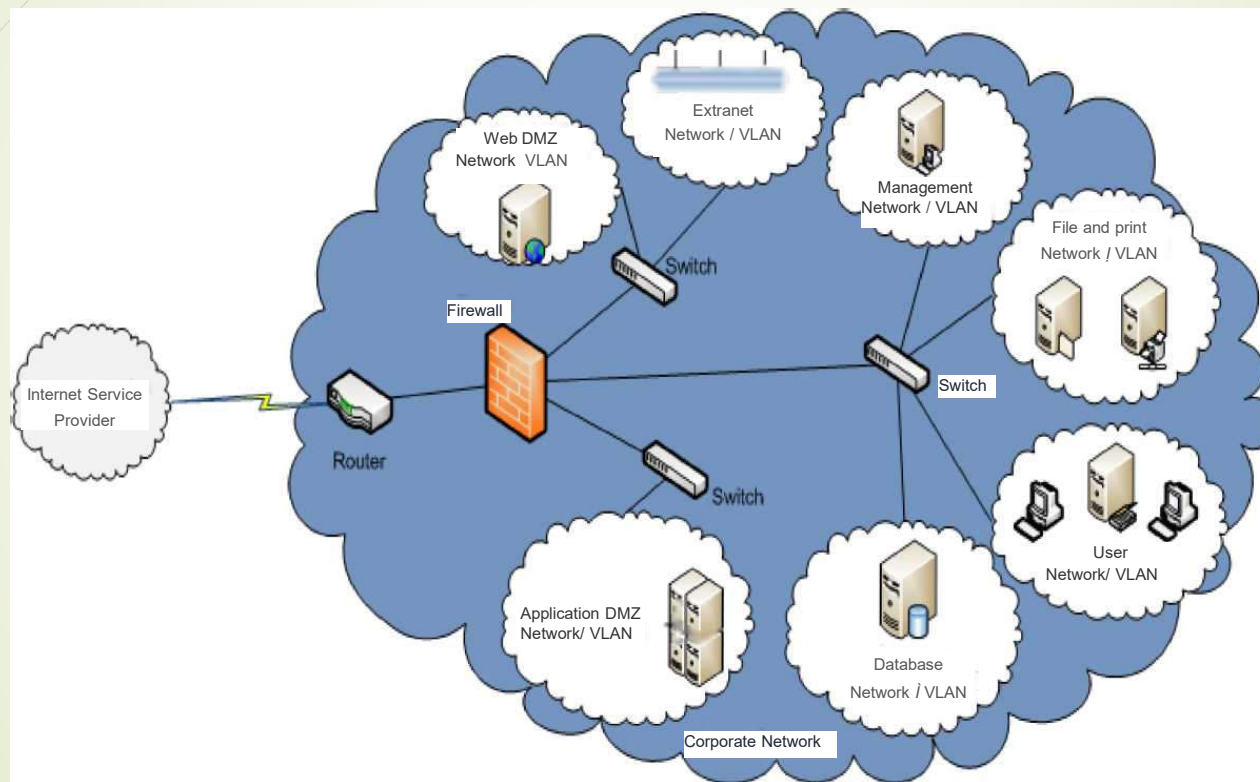
Quản lý các điểm truy nhập



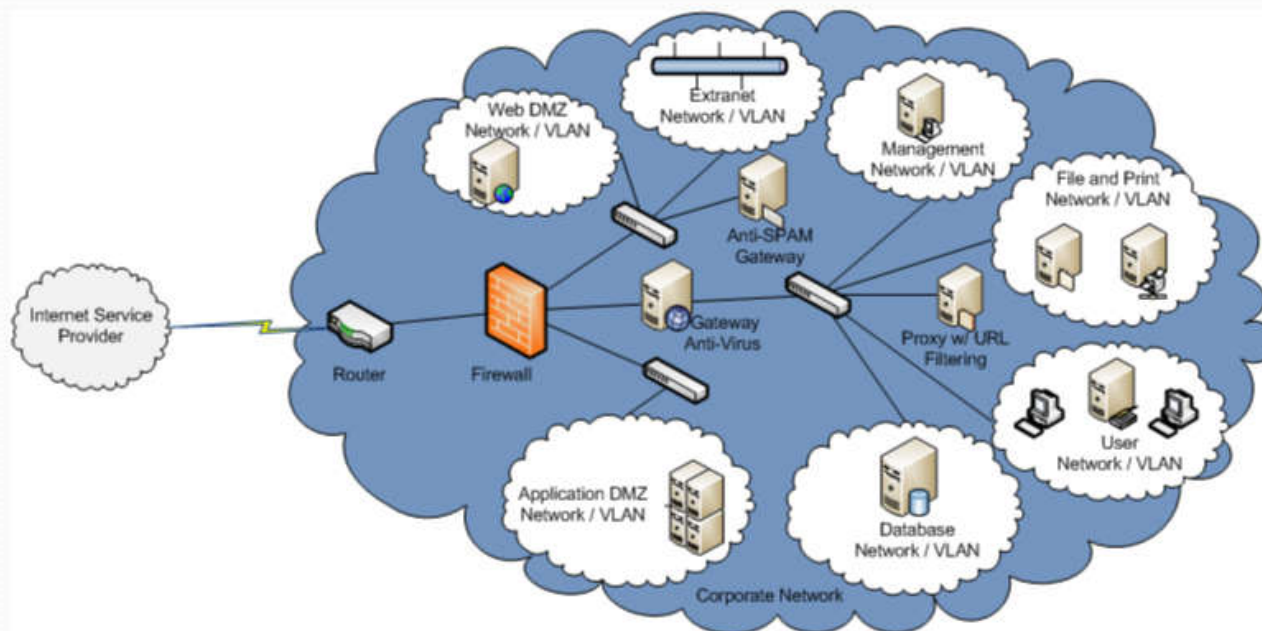
Các bộ định tuyến và chuyển mạch



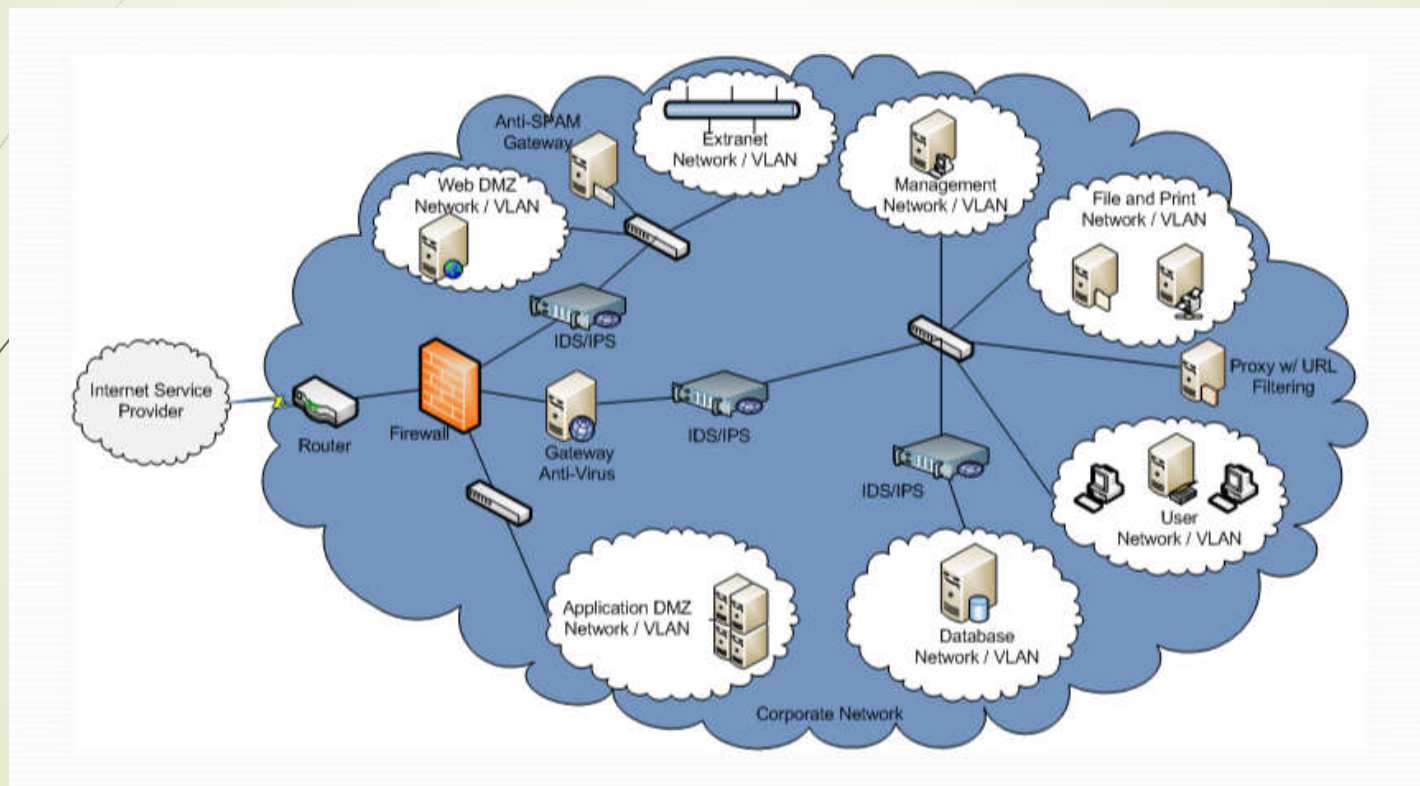
Tường lửa (Firewall)



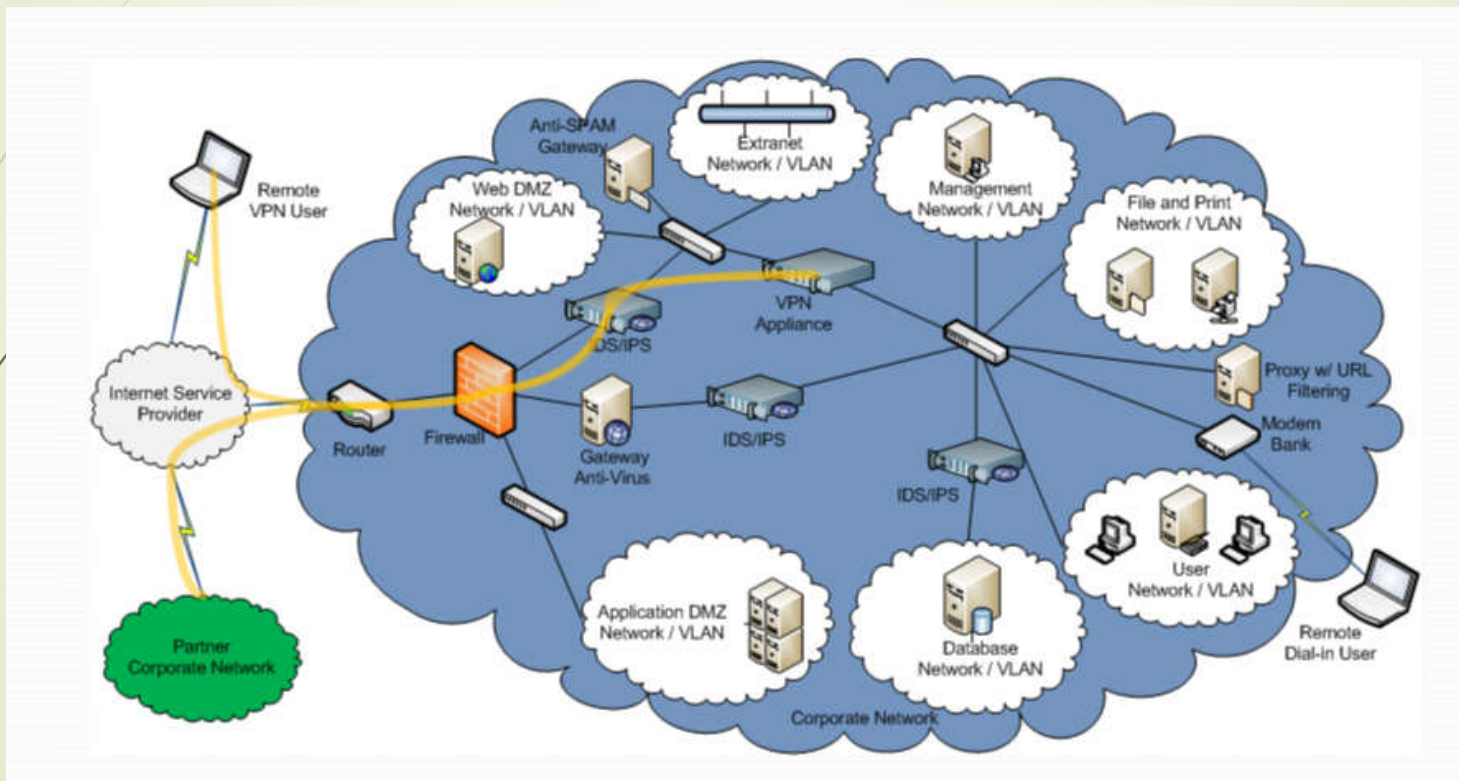
Lọc nội dung



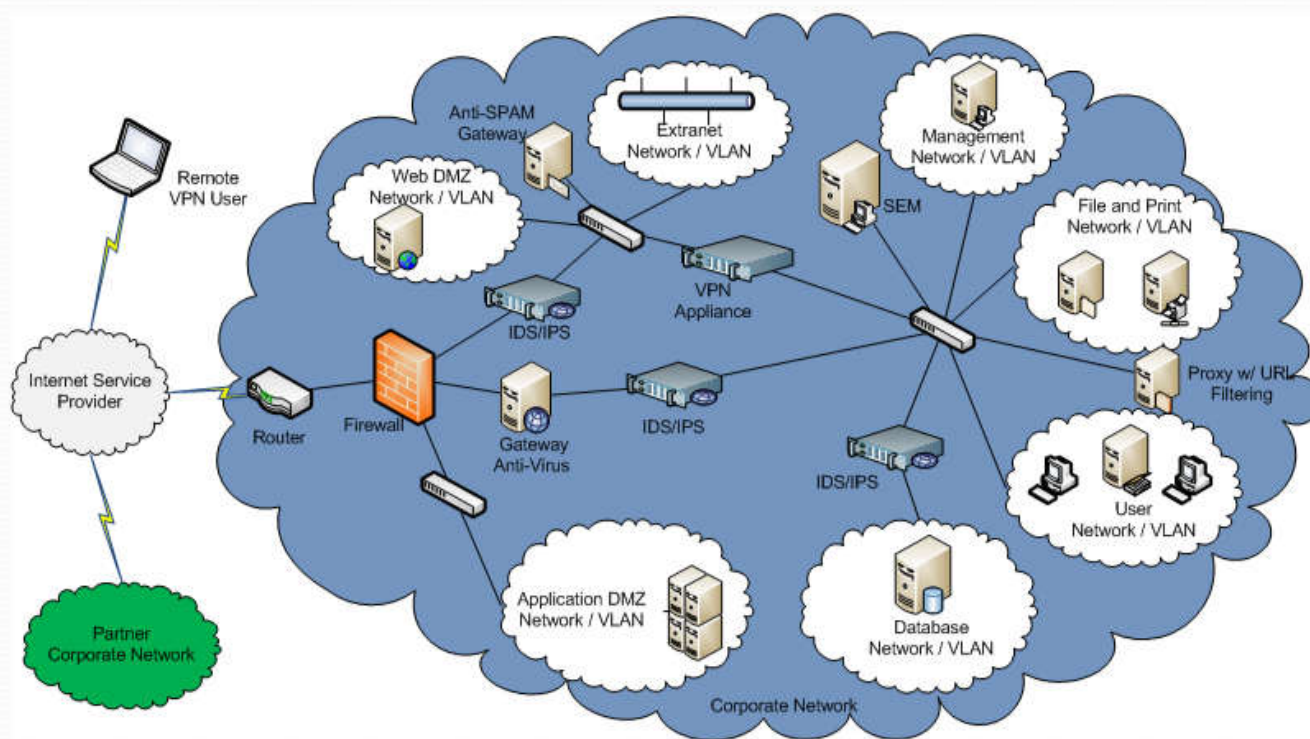
Các thiết bị phòng chống và phát hiện xâm nhập



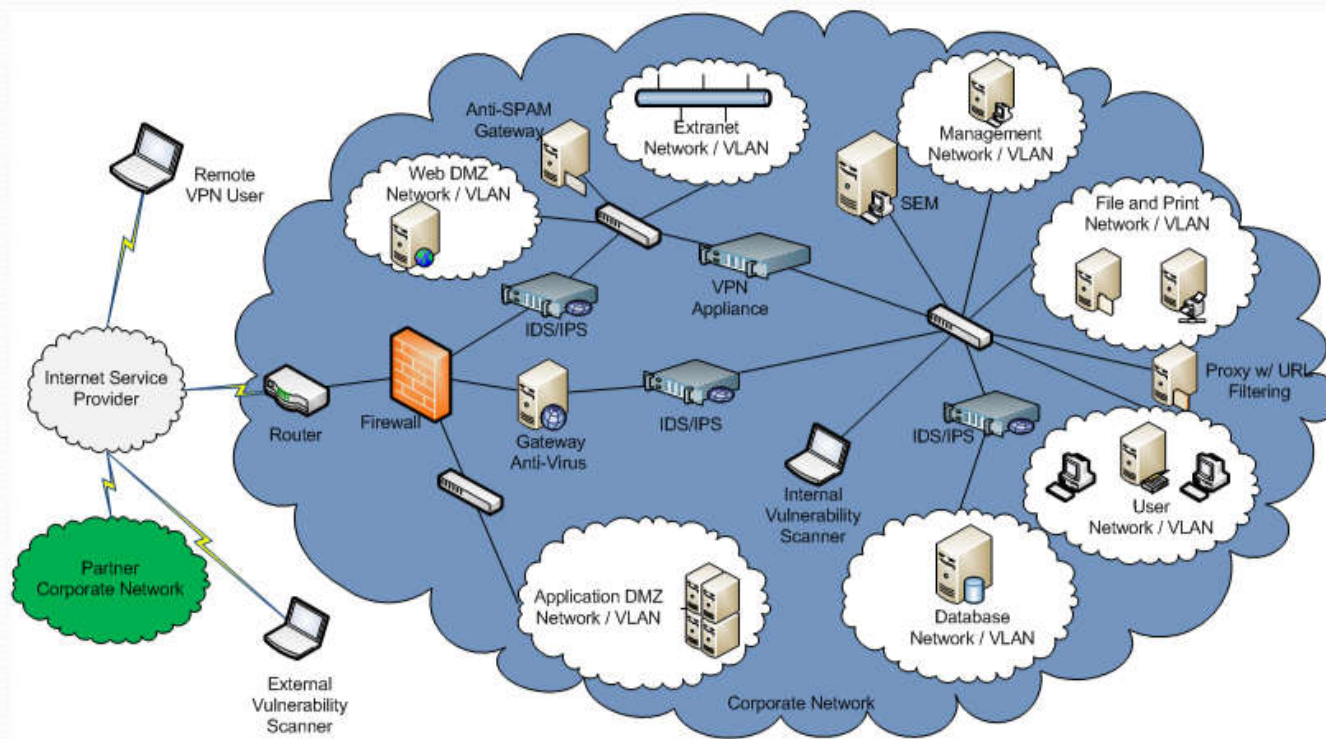
Điều khiển truy nhập từ xa



Quản lý các sự kiện an ninh



Quản lý tổn thương



Sử dụng mật mã

